

TechFlow Solutions

Security & Technical Architecture

Version 2.8 | Q1 2025 | Confidential

1. Security Philosophy & Framework

Security at TechFlow is not a feature - it is a foundational principle woven into every aspect of our platform design, development, and operations. We follow a defense-in-depth strategy with multiple overlapping layers of security controls.

1.1 Security Principles

- Zero Trust Architecture: Every request is authenticated and authorized regardless of network location. Internal services use mutual TLS (mTLS) for all communication.
- Least Privilege: Access is granted on a need-to-know basis with just-in-time elevation for administrative operations.
- Defense in Depth: Multiple independent security controls at each layer (network, application, data, identity) ensure no single failure compromises security.
- Shift Left: Security testing is integrated into the CI/CD pipeline with automated SAST, DAST, SCA, and container scanning on every commit.
- Assume Breach: Our architecture is designed assuming any component could be compromised. Blast radius limitation, microsegmentation, and comprehensive logging ensure rapid detection and containment.

1.2 Security Team

The TechFlow Security team consists of 18 specialists reporting to CISO Amanda Washington (formerly NSA TAO and then Google Cloud Security). The team includes: Security Engineering (8 engineers building security tooling and infrastructure), Security Operations (5 analysts in a 24/7 SOC), Governance Risk & Compliance (3 specialists managing audits and certifications), and Application Security (2 engineers focused on secure development practices and code review).

1.3 Security Governance

Security governance at TechFlow includes: quarterly security reviews with the board of directors, monthly security metrics review with the executive team, bi-weekly vulnerability management meetings, weekly security incident review, and daily SOC stand-ups. All security decisions are documented in our internal wiki.

2. Identity & Access Management

2.1 Customer IAM

TechFlow provides a comprehensive IAM system for customers to manage access to their resources. Features include role-based access control (RBAC), attribute-based access control (ABAC), multi-factor authentication (MFA), single sign-on (SSO) via SAML 2.0 and OIDC, API keys with granular permissions, and service accounts for automation.

Feature	Basic	Professional	Enterprise
Team Members	5	25	Unlimited
Custom Roles	No	5	Unlimited
MFA	TOTP only	TOTP + WebAuthn	TOTP + WebAuthn + Hardware
SSO	No	SAML 2.0	SAML 2.0 + OIDC + SCIM
API Keys	5	25	Unlimited
Audit Log Retention	30 days	90 days	1 year + export
IP Allowlisting	No	No	Yes
Session Management	Basic	Configurable	Advanced + SSO enforcement

2.2 Internal Access Controls

TechFlow employees access production systems through a bastion host architecture with mandatory MFA (YubiKey hardware tokens) and just-in-time access provisioning. All production access is time-limited (maximum 4 hours per session), logged, and reviewed by the security team within 24 hours. Privileged access requires approval from two managers and is restricted to the Security and SRE teams.

Customer data access by TechFlow employees is prohibited except during active support incidents with explicit customer consent. All such access is logged with customer-visible audit trails. Annual access reviews ensure compliance with the principle of least privilege.

3. Network Security Architecture

3.1 Network Topology

TechFlow's network is segmented into distinct security zones with strict firewall rules governing traffic between zones. The architecture includes:

- DMZ: Hosts load balancers, CDN edge nodes, and API gateways. Only zone exposed to the public internet.
- Application Zone: Hosts customer VPS, containers, and serverless functions. Isolated per customer using VXLAN overlay networks.
- Data Zone: Hosts managed databases, object storage, and data processing clusters. No direct internet access; only reachable from the Application Zone.
- Management Zone: Hosts monitoring, logging, and administrative systems. Accessible only via bastion hosts with MFA.
- Control Plane: Hosts Kubernetes API servers, identity providers, and orchestration systems. Highly restricted access with dedicated hardware security modules (HSMs).

3.2 DDoS Protection

All TechFlow services include built-in DDoS protection at no additional cost. Our multi-layered DDoS mitigation system handles: Layer 3/4 volumetric attacks (up to 5 Tbps mitigation capacity through Anycast routing and traffic scrubbing), Layer 7 application attacks (rate limiting, challenge pages, bot detection), and DNS amplification attacks (rate limiting and response size filtering).

For customers requiring advanced protection, TechFlow Shield (\$500/month) adds: dedicated IP pools not shared with other customers, custom WAF rules with managed rule sets (OWASP Top 10, bot management, API protection), real-time attack visibility dashboard, and 24/7 DDoS response team engagement for attacks exceeding normal parameters.

3.3 Private Networking

Customers can create Virtual Private Clouds (VPCs) with custom CIDR ranges, subnets, and routing tables. VPC features include: private subnets with no internet access for sensitive workloads, NAT gateways for controlled outbound internet access, VPC peering for connecting multiple VPCs (same or cross-region), VPN gateways for site-to-site connections (IPsec, WireGuard), and private endpoints for accessing TechFlow managed services without internet transit.

3.4 DNS Security

TechFlow DNS provides authoritative DNS hosting with built-in security features: DNSSEC support for domain validation, DNS-over-HTTPS (DoH) and DNS-over-TLS (DoT), automated DNS failover with health checking, and DDoS-resilient infrastructure with Anycast deployment across 200+ locations.

4. Data Security & Encryption

4.1 Encryption at Rest

All data stored on TechFlow infrastructure is encrypted at rest using AES-256 encryption. This applies to VPS disks, managed databases, object storage, backups, and log archives. Encryption is transparent to customers with zero performance impact.

Key management options include: TechFlow-managed keys (default, no configuration required), customer-managed keys via our Key Management Service (KMS), and Bring Your Own Key (BYOK) with customer-controlled HSM integration.

4.2 Encryption in Transit

All network traffic within TechFlow infrastructure is encrypted using TLS 1.3 for external connections and mutual TLS (mTLS) for internal service-to-service communication. We support Perfect Forward Secrecy (PFS) on all TLS connections and disable TLS 1.0/1.1 by default. Certificate management is automated via our internal PKI, with certificates rotated every 90 days.

4.3 Key Management Service (KMS)

TechFlow KMS provides centralized key management for cryptographic operations. Keys are stored in FIPS 140-2 Level 3 certified HSMs. Features include: symmetric and asymmetric key support (AES-256, RSA-2048/4096, ECDSA P-256/P-384), automatic key rotation (configurable 90/180/365 days), key usage auditing with detailed logs, cross-region key replication for DR, and API-based encryption/decryption operations for application-level encryption.

KMS Feature	Basic	Professional	Enterprise
Keys	5	50	Unlimited
HSM-backed	Shared	Shared	Dedicated
Custom Key Import	No	Yes	Yes
Auto-rotation	Annual	Configurable	Configurable
API Calls/mo	10K	100K	Unlimited
Price/key/mo	\$1	\$1	\$3 (dedicated HSM)

4.4 Data Classification

TechFlow recommends customers classify their data into four tiers: Public (no restrictions, cached at CDN edge), Internal (encrypted at rest, access logging), Confidential (encrypted + access controls + audit trails), and Restricted (dedicated infrastructure + customer-managed keys + enhanced monitoring). Our platform enforces data classification through tagging and policy rules.

5. Application Security

5.1 Secure Development Lifecycle

TechFlow follows a rigorous Secure Development Lifecycle (SDL) for all platform code. Every code change goes through: peer code review (minimum 2 reviewers), automated static analysis (SAST) using Semgrep and CodeQL, dependency scanning (SCA) using Snyk, dynamic application security testing (DAST) in staging environments, and container image scanning for known vulnerabilities (CVEs).

5.2 Vulnerability Management

Our vulnerability management program includes continuous scanning of all production systems, third-party penetration testing (annually by NCC Group), a public bug bounty program on HackerOne (paid \$280K in bounties in 2024), and vendor security assessments for all third-party integrations.

Severity	SLA for Patch	Examples
Critical (CVSS 9.0+)	24 hours	RCE, auth bypass, data exfiltration
High (CVSS 7.0-8.9)	7 days	Privilege escalation, SSRF, SQLi
Medium (CVSS 4.0-6.9)	30 days	XSS, info disclosure, DoS
Low (CVSS 0.1-3.9)	90 days	Minor info leak, cosmetic issues

5.3 Web Application Firewall (WAF)

TechFlow WAF provides Layer 7 protection for web applications with managed rule sets covering: OWASP Top 10 vulnerabilities (SQL injection, XSS, CSRF, etc.), known malicious IP reputation lists (updated every 5 minutes), bot detection and management (good bot allowlisting, bad bot blocking), API abuse prevention (rate limiting, schema validation), and custom rules using our expression language.

WAF pricing: \$50/month per domain with 1M inspected requests included, then \$0.60 per additional 1M requests. Available as a load balancer add-on or standalone edge deployment.

6. Infrastructure Architecture

6.1 Data Center Locations

TechFlow operates infrastructure in 8 regions across 3 continents, each consisting of 2-3 independent availability zones for fault isolation:

Region	Location	AZs	Launched	Certifications
us-east-1	Virginia, USA	3	2018	SOC2, HIPAA, PCI, FedRAMP
us-west-1	Oregon, USA	3	2018	SOC2, HIPAA, PCI
eu-west-1	Frankfurt, DE	3	2020	SOC2, ISO27001, GDPR
eu-west-2	Amsterdam, NL	2	2022	SOC2, ISO27001, GDPR
uk-south-1	London, UK	2	2021	SOC2, ISO27001, UK DPA
ap-south-1	Singapore	3	2021	SOC2, ISO27001, PDPA
ap-north-1	Tokyo, Japan	2	2022	SOC2, ISO27001, APPI
ap-south-2	Sydney, AU	2	2023	SOC2, ISO27001, APPs

6.2 Hardware Specifications

Our compute fleet is standardized on the following hardware generations:

- Gen 5 (current): AMD EPYC 9654 96-core, 768 GB DDR5, 30 TB NVMe Gen4
- Gen 4 (legacy): Intel Xeon Platinum 8380 40-core, 512 GB DDR4, 20 TB NVMe Gen3
- GPU Fleet: NVIDIA H100 80GB (training), A100 80GB (inference), T4 16GB (dev/test)
- Networking: Arista 7800R3 spine switches with 400GbE fabric, Mellanox ConnectX-7
- Storage: Pure Storage FlashArray//X for block, custom Ceph clusters for object

6.3 Capacity Planning

TechFlow maintains a minimum of 30% excess capacity across all regions for burst handling and growth. Capacity planning reviews occur monthly with automated alerts when utilization exceeds 60% in any zone. New hardware procurement cycle is 8-12 weeks, so we maintain rolling 6-month capacity forecasts based on customer growth trends.

7. Reliability Engineering

7.1 SRE Practices

TechFlow's Site Reliability Engineering team follows Google SRE principles adapted for our scale. Key practices include: error budgets (each service has an SLO with a corresponding error budget that gates feature velocity), toil reduction (automated runbooks for 85% of common operational tasks), blameless post-mortems (published internally within 48 hours of any SEV-1/2 incident), and chaos engineering (monthly game days testing failure scenarios in staging and quarterly in production).

7.2 Incident Management

Our incident management process follows the ICS (Incident Command System) framework:

- Detection: Automated monitoring alerts via PagerDuty (average MTTD: 2 minutes)
- Triage: On-call engineer assesses severity and initiates war room if SEV-1/2
- Response: Incident commander coordinates cross-functional response team
- Communication: Customer-facing status page updated within 10 minutes of detection
- Resolution: Root cause identification and fix deployment
- Post-mortem: Blameless review within 48 hours, action items tracked to completion

Key metrics (2024): Mean Time to Detect (MTTD): 2.1 minutes, Mean Time to Acknowledge (MTTA): 4.3 minutes, Mean Time to Resolve (MTTR): 47 minutes for SEV-1, 2.3 hours for SEV-2. Total SEV-1 incidents: 3 (all resolved within SLA).

7.3 Change Management

All production changes follow our change management process: changes are classified as standard (pre-approved, automated), normal (requires peer review and approval), or emergency (expedited for active incidents). Normal changes require: pull request with 2+ approvals, passing CI/CD pipeline (tests, security scans), staged rollout (canary deployment to 5% of traffic, then 25%, 50%, 100%), and automated rollback trigger if error rate exceeds 0.1% during any rollout stage.

7.4 Capacity & Performance

TechFlow's platform handles the following aggregate metrics: 2.5 million API requests per second, 800 Gbps aggregate network throughput, 15 PB total managed storage, 50,000 active VPS instances, 8,000 managed database clusters, and 200 million CDN requests per hour. P99 API response time: 45ms.

8. Monitoring & Logging Architecture

8.1 Monitoring Stack

TechFlow's internal monitoring infrastructure processes over 50 billion data points per day across metrics, logs, and traces. Our stack includes: Prometheus for metrics collection (federation across all regions), Grafana for visualization (2,500+ dashboards), Loki for log aggregation, Tempo for distributed tracing, and AlertManager for alert routing and deduplication.

8.2 Customer-Facing Monitoring

Every TechFlow customer has access to a monitoring dashboard showing: resource utilization (CPU, memory, disk, network) at 10-second granularity, application metrics (request rate, error rate, latency percentiles), database metrics (queries per second, connection pool, replication lag), and cost tracking (real-time spend and forecast).

8.3 Audit Logging

TechFlow maintains comprehensive audit logs for all API calls, console actions, and system events. Audit logs capture: who performed the action (user, API key, service account), what action was performed (CRUD operation, resource type), when the action occurred (microsecond precision, UTC), where the request originated (IP address, user agent, geographic location), and whether the action succeeded or was denied (with denial reason).

Audit log retention varies by plan: Basic (30 days), Professional (90 days), Enterprise (1 year with export to customer's own storage for indefinite retention). Logs are immutable and cryptographically signed to ensure integrity.

9. API Architecture & Developer Tools

9.1 API Design

All TechFlow services are accessible via RESTful APIs following consistent design principles: JSON request/response format, OAuth 2.0 and API key authentication, semantic versioning with 12-month deprecation policy, rate limiting with clear headers (X-RateLimit-Limit, X-RateLimit-Remaining), pagination using cursor-based navigation, and comprehensive error responses with actionable messages.

9.2 SDKs & CLI

Official SDKs are available for: Python (pip install techflow-sdk), Node.js (npm install @techflow/sdk), Go (go get github.com/techflow/sdk-go), Java (Maven central: com.techflow: sdk), Ruby (gem install techflow), and Rust (cargo add techflow-sdk). All SDKs are open-source and accept community contributions.

The TechFlow CLI (tf) provides command-line access to all platform features with shell completion, output formatting (JSON, YAML, table), and scriptability. Installation: brew install techflow/tap/tf (macOS), apt-get install techflow-cli (Ubuntu), or binary download from cli.techflow.io.

9.3 API Rate Limits

Plan	Requests/sec	Burst	Concurrent
Basic	10	50	5
Professional	50	200	25
Enterprise	500	2,000	100
Custom	Negotiable	Negotiable	Negotiable

9.4 Webhooks

TechFlow supports outbound webhooks for real-time event notifications. Events include: resource lifecycle (created, updated, deleted), alerts and incidents, billing events (threshold reached, invoice generated), and security events (login, permission change, API key rotation). Webhooks support HMAC-SHA256 signature verification, automatic retry with exponential backoff (up to 72 hours), and dead-letter queue for failed deliveries.

10. Disaster Recovery Architecture

10.1 Multi-Region Design

TechFlow's control plane is deployed in an active-active configuration across three primary regions (us-east-1, eu-west-1, ap-south-1). Each region can independently serve all API requests and manage resources. Data replication between regions uses our custom consensus protocol based on Raft with sub-second replication lag for metadata and configurable async replication for customer data.

10.2 Backup Architecture

Backup infrastructure is independent from production systems with dedicated storage clusters in separate availability zones. Backup data is encrypted with separate keys from production and stored in a different cloud provider for additional resilience. Backup integrity is verified daily through automated restore tests on 1% of randomly selected backups.

10.3 DR Testing

TechFlow conducts disaster recovery exercises quarterly: tabletop exercises (simulated scenarios reviewed by the leadership team), partial failover tests (individual service failover to secondary region), and full failover tests (annual exercise failing over an entire region). Results are documented and shared with Enterprise customers upon request.

Our last full DR test (November 2024) achieved: complete region failover in 3 minutes and 42 seconds, zero data loss (RPO = 0), all services operational in secondary region within 5 minutes, and customer traffic re-routed via DNS with average propagation time of 47 seconds.

11. Compliance Deep Dive

11.1 SOC 2 Type II

TechFlow's SOC 2 Type II report covers all five trust service criteria: Security (logical and physical access controls, encryption, monitoring), Availability (infrastructure redundancy, DR procedures, SLAs), Processing Integrity (quality assurance, change management, error handling), Confidentiality (data classification, encryption, access controls), and Privacy (data collection, use, retention, and disposal policies).

Our most recent audit (December 2024, conducted by Deloitte) found zero exceptions across all trust service criteria. The report is available to customers under NDA through their Customer Success Manager or the security portal.

11.2 HIPAA Compliance

TechFlow signs Business Associate Agreements (BAAs) with healthcare customers. HIPAA-eligible services include: VPS (dedicated instances), Managed PostgreSQL and MySQL, Object Storage, Load Balancer, and Monitoring. HIPAA-compliant configurations include: dedicated infrastructure (no shared tenancy), audit logging with 6-year retention, encryption at rest with customer-managed keys, and automated PHI detection and alerting.

11.3 PCI DSS 4.0

For customers processing payment card data, TechFlow provides PCI DSS 4.0 compliant infrastructure. Our platform is certified as a PCI Level 1 Service Provider (the highest level). PCI-scoped services include: dedicated VPS instances in a CDE (Cardholder Data Environment), managed databases with field-level encryption, WAF with PCI-specific rule sets, and network segmentation enforced via dedicated VLANs.

11.4 GDPR & Data Privacy

TechFlow's GDPR compliance framework includes: Data Processing Agreement (DPA) as a standard contract attachment, data residency options (EU-only processing), right to erasure (automated data deletion within 30 days of request), data portability (export all data in standard formats), privacy impact assessments for new features, appointed Data Protection Officer (DPO): Dr. Eva Mueller, Berlin office, and Standard Contractual Clauses for international transfers.

11.5 FedRAMP

TechFlow is pursuing FedRAMP Moderate authorization with an expected completion date of Q3 2025. The us-east-1 region has been designated as the FedRAMP boundary with additional controls including: FIPS 140-2 validated encryption modules, US-person-only access for administrative functions, continuous monitoring with NIST 800-53 Rev 5 controls, and Plan of Action and Milestones (POA&M) tracking.

12. Network Performance & Optimization

12.1 Global Network

TechFlow operates a private backbone network connecting all 8 regions with dedicated fiber capacity. Our network provides: 25 Tbps total backbone capacity, direct peering with 500+ ISPs and content networks, private interconnects at 30+ colocation facilities (Equinix, Digital Realty, CoreSite), and edge PoPs in 200+ cities for CDN and DNS services.

12.2 Latency Benchmarks

Route	Average Latency	P99 Latency	Packet Loss
us-east <-> us-west	62ms	68ms	< 0.001%
us-east <-> eu-west	78ms	85ms	< 0.001%
us-east <-> ap-south	185ms	195ms	< 0.002%
eu-west <-> ap-south	145ms	155ms	< 0.001%
Same-region AZ-to-AZ	< 1ms	< 2ms	< 0.0001%
Same-AZ instances	< 0.1ms	< 0.3ms	< 0.00001%

12.3 Traffic Engineering

TechFlow uses intelligent traffic engineering to optimize routing: BGP Anycast for DNS and CDN (users connect to nearest PoP), ECMP (Equal-Cost Multi-Path) for internal traffic distribution, segment routing for traffic engineering within our backbone, and real-time path optimization based on latency, packet loss, and congestion measurements.

13. Operational Procedures

13.1 Maintenance Windows

Scheduled maintenance is performed during off-peak hours with advance notification. Standard maintenance window: Tuesday and Thursday, 2-6 AM local time (based on region). Emergency maintenance may occur at any time but triggers automatic service credits if it impacts availability. Notification timeline: 72 hours for standard maintenance, 24 hours for urgent maintenance, immediate for emergency maintenance (via status page, email, and Slack).

13.2 Deployment Practices

TechFlow deploys changes to production multiple times per day using a staged rollout process. Typical deployment pipeline: automated tests in CI (unit, integration, e2e), deployment to staging with automated smoke tests, canary deployment to 5% of production traffic, progressive rollout (25%, 50%, 100%) with automated health checks at each stage, and automated rollback if any stage fails health checks.

13.3 On-Call Rotations

Each product squad maintains a 24/7 on-call rotation with primary and secondary engineers. On-call shifts are 1 week long with handoff meetings every Monday. On-call engineers are compensated with: additional pay (\$500/week), time off in lieu for overnight pages, and a maximum of 2 incidents per night before the secondary engineer takes over.

13.4 Communication Protocols

During incidents, TechFlow uses the following communication channels: status.techflow.io (public status page with RSS/Atom/JSON feeds and email/SMS subscriptions), Slack (private channel for Enterprise customers, shared channel for Professional), email (automated notifications for all severity levels), and phone (proactive outbound calls for SEV-1 incidents affecting Enterprise customers).

14. Future Architecture Roadmap

14.1 2025 Infrastructure Investments

- New regions: Canada (Montreal), Brazil (Sao Paulo), India (Mumbai) planned for H2 2025
- Hardware refresh: Gen 6 compute (AMD EPYC 9754 128-core) deployment beginning Q3 2025
- Network upgrade: 800GbE spine fabric rollout across all regions
- GPU expansion: NVIDIA B200 clusters for next-gen ML training workloads
- Storage: New all-flash object storage tier with 10x IOPS improvement

14.2 Platform Evolution

- Multi-cloud control plane: manage resources across TechFlow, AWS, GCP, and Azure from a single API
- Edge computing expansion: serverless functions at all 200+ CDN PoPs
- AI-native infrastructure: dedicated inference accelerators, model caching at edge
- Confidential computing: AMD SEV-SNP and Intel TDX for encrypted VMs
- Green computing: workload scheduling that optimizes for carbon intensity of grid power

14.3 Security Enhancements

- Post-quantum cryptography: hybrid key exchange (X25519 + ML-KEM) for TLS
- Hardware attestation: TPM-based verification of VPS boot integrity
- AI-powered threat detection: anomaly detection for API abuse and account compromise
- Supply chain security: SLSA Level 4 for all platform releases
- Passkey support: WebAuthn/FIDO2 for passwordless authentication